

Week 6 Day 2

SAST (Static Application Security Testing)

Here we analyze source code, binaries or bytecode to identify vulnerabilities without application

1. SQL Injection (A03- Injection)

Malicious queries manipulate database to access or alter data. There are 3 levels of SQL Injection:

- a) Low Security - The application directly puts the user's input into SQL query.
- b) Medium Security - The application tries to protect input by escaping special characters.
- c) High Security

The application uses a prepared statement, which separates the SQL command from the user's inputs.

Type of SQL Injection

- i) Error based SQL Injection
- ii) Union based SQL Injection
- iii) Blind SQL Injection

2. XSS (Cross Site Scripting) (A07)

It is a web security vulnerability where an attacker injects malicious JS into a website, which then runs in another user's browser.

Types of XSS

a) Stored XSS

Malicious script is saved on the server/database and runs when users view the page.

b) Reflected XSS

Malicious script input is immediately reflected in the website's response.

c) DOM-based XSS

JavaScript in the browser modifies the page using unsafe user input.

- Steal session cookies
- Perform action as another user
- Redirect users to malicious website
- Deliver malware.

3. Command Injection

Unauthorized system commands executed via unsanitized input.

4. Insecure Authentication (A07)

Weak login mechanisms or poor session handling

5. Buffer Overflows

Memory corruption due to excess data input.

6. Cross Site Request Forgery (CSRF)

It is a web attack where an attacker tricks a logged-in user into performing an unwanted action on a website.

7. Sensitive data exposure

It means an unauthorized person have the access to the sensitive data of user which could be obtained through data breach. are some one getting access to the database. To prevent it we must always encrypt the user data.



Mo	Tu	We	Th	Fr	Sa	Su
----	----	----	----	----	----	----

Memo No. _____

Date / /

8. Manual Penetration Testing

It uses ~~human~~ human expertise, to simulate a real sophisticated attacks to uncover. Business-logic, chaining vulnerabilities, social-engineering vectors.